

Week 4: Symmetric Cryptography

Instructor: Dr. Thilini Dahanayaka / Dr. Suranga Seneviratne

1. Cryptography Fundamentals & Definitions

Cryptography is the science of securely transmitting data **spatially** (over distance) and **temporally** (over time).

- **Plaintext (p):** Unprotected data.
- **Ciphertext (c):** Encrypted data.
- **Encryption (Enc):** $Enc_{k_e}(p) = c$
- **Decryption (Dec):** $Dec_{k_d}(c) = p$

Two Main Forms

1. **Symmetric Cryptography (Shared-Key):** $k_e = k_d$ (or k_d is easily derived from k_e). Focus of this lecture.
2. **Asymmetric Cryptography (Public-Key):** $k_e \neq k_d$ (infeasible to compute k_d from k_e).

🚨 **EXAM RELEVANT: Kerckhoffs' Principle** The security of a cryptographic mechanism must depend **ONLY on the secrecy of the keys**, never on the secrecy of the algorithm itself. (e.g., AES is public; its security relies on the private key).

Security Goals

- **Confidentiality:** Achieved via encryption.
- **Integrity:** Achieved via Message Authentication Codes (MACs), signatures, hash functions.
- **Authentication & Non-repudiation:** Achieved via signatures and protocols.

2. Attack Models (Cryptanalysis)

- **Ciphertext-only:** Attacker only has ciphertext. (Hardest attack).
- **Known plaintext:** Attacker has some plaintext and its corresponding ciphertext. (e.g., Bletchley Park knowing weather report formats).
- **Chosen plaintext:** Attacker can choose plaintexts and observe the resulting ciphertexts.
- **Chosen ciphertext:** Attacker can choose ciphertexts and observe the decrypted plaintexts (Oracle attacks).

3. Historical Ciphers & Core Concepts

Historical ciphers rely on two techniques:

- **Substitution:** Replacing symbols (e.g., Caesar Cipher).
- **Transposition:** Shifting positions of symbols (e.g., Rail Fence Cipher).

Vigenère Cipher (Polyalphabetic Substitution)

Uses a keyword to apply a series of different Caesar ciphers.

- **Encryption:** $C_i = (P_i + K_{i \bmod |K|}) \bmod 26$
- **Decryption:** $P_i = (C_i - K_{i \bmod |K|} + 26) \bmod 26$

- **Vulnerability:** Can be broken using the **Kasiski Test** if the key length is unknown, by finding repeating patterns to deduce key length (looking at greatest common divisors of repeating interval distances), then using frequency analysis.

Modern Cipher Design Goals (Shannon)

🚩 EXAM RELEVANT: Confusion vs. Diffusion

- **Confusion:** Blurs the relationship between the **ciphertext and the key**. (Achieved via **Substitution / S-Boxes**).
- **Diffusion:** Spreads the influence of one **plaintext bit over many ciphertext bits**. (Achieved via **Transposition / Permutation / P-Boxes**). On average, flipping 1 plaintext bit should flip 50% of ciphertext bits.

4. Stream Ciphers vs. Block Ciphers

Stream Ciphers

Encrypts data one bit/byte at a time.

- Generates a pseudorandom keystream b from a seed (secret key k).
- **Ciphertext:** $c = p \oplus b$ (XOR operation).
- **Rule:** Keystream must be indistinguishable from random. Never reuse the keystream (nonce/IV).
- **Examples:** ChaCha20, Salsa20 (Current standards); RC4 (Avoid/Insecure).

One-Time Pad (OTP) Achieves Perfect Secrecy: Ciphertext yields no information about plaintext.

- **Conditions:** Key (o) must be truly random, $|o| \geq |p|$ (key as long as plaintext), and **NEVER reused**.
- **Impracticality:** Key distribution and generation of massive random keys is too difficult.
- **Vulnerability (Two-Time Pad):** If key K is reused: $C_1 \oplus C_2 = P_1 \oplus P_2$. Attackers can use "crib dragging" to guess words.

Block Ciphers

Encrypts data in fixed-size blocks (e.g., 64 or 128 bits). Uses S-boxes (Substitution) and P-boxes (Permutation) arranged in networks over multiple rounds.

- **Examples:** DES, 3DES, AES.

5. Feistel Networks & DES

Feistel Cipher Structure

Divides block into left (L) and right (R) halves. Over multiple rounds n :

1. R goes through a function F (using a round key).
2. Output of F is XORed with L to become the new R_{n+1} .
3. The old R_n becomes the new L_{n+1} . *Used in DES. Ensures decryption is possible even if function F is not invertible.*

Data Encryption Standard (DES) (🚩 Insecure)

- **Structure:** 16 rounds of a Feistel network.
- **Specs:** 64-bit blocks, **56-bit key**.
- **Components:** 8 S-boxes (6-bit input $\rightarrow$ 4-bit output).
- **Why insecure?:** Key space (2^{56}) is too small. Can be brute-forced in hours/days with modern computing.

Reading an S-Box (Example): Input: 010000

- Outer bits (0 . . . 0 $\rightarrow$ 0) = Row 0
- Inner bits (1000 $\rightarrow$ 8) = Column 8
- Find intersection in table, convert to 4-bit binary.

3DES (Triple DES)

- Runs DES three times: Encrypt (K_1) $\rightarrow$ Decrypt (K_2) $\rightarrow$ Encrypt (K_3).
- Effective key size: 112 or 168 bits.
- Why E-D-E? Backward compatibility: if $K_1 = K_2 = K_3$, it acts exactly like single DES.

Block Cipher Design Principles for Function F

- **Strict Avalanche Criterion (SAC):** Flipping 1 input bit changes each output bit with 50% probability.
- **Bit Independence Criterion (BIC):** Output bits change independently when 1 input bit changes.

6. Advanced Encryption Standard (AES)

- **Current Standard.** Replaced DES. (Originally the Rijndael cipher).
- **Structure:** Substitution-Permutation Network (SPN), *not* Feistel.
- **Specs:** 128-bit block size. Key sizes: 128, 192, or 256 bits (10, 12, or 14 rounds respectively).
- **Math Basis:** Operations over the finite field $GF(2^8)$. (Addition is XOR).

Four Stages per AES Round:

1. **Substitute bytes:** Byte-by-byte substitution via S-box (Confusion).
2. **ShiftRows:** Simple permutation/transposition (Diffusion).
3. **MixColumns:** Arithmetic over $GF(2^8)$ (Diffusion).
4. **AddRoundKey:** Bitwise XOR with expanded round key.

7. Cipher Block Modes

How to handle messages larger than one block.

1. **ECB (Electronic Codebook) - 🚩 DO NOT USE**
 - $C_i = Enc_k(P_i)$
 - **Flaw:** Identical plaintext blocks produce identical ciphertext blocks. Preserves visual patterns (e.g., the encrypted Linux penguin image).
2. **CBC (Cipher Block Chaining)**
 - $C_i = Enc_k(P_i \oplus C_{i-1})$
 - XORs plaintext with previous ciphertext block *before* encryption.

- Requires an **Initialization Vector (IV)** for the first block. IV doesn't need to be secret, but **must never be repeated** with the same key.
- **Flaw:** Sequential, cannot be parallelized.

3. CTR (Counter Mode)

- Encrypts a Counter + Nonce to create a keystream, then XORs with plaintext (turns a block cipher into a stream cipher).
- Highly efficient, can be parallelized. Nonce must never be reused.

4. AE / AEAD (Authenticated Encryption)

- Modern modes (GCM, CCM) that provide both confidentiality (encryption) AND integrity (authentication) simultaneously.

8. Pseudorandom Number Generators (PRNG)

- **PRNG:** Deterministic sequence based on a seed.
- **CSPRNG (Cryptographically Secure PRNG):**
 1. Computationally infeasible to brute-force the seed to predict output.
 2. Output is indistinguishable from true randomness.
- Used for generating session keys, IVs, nonces, and stream cipher bit streams.